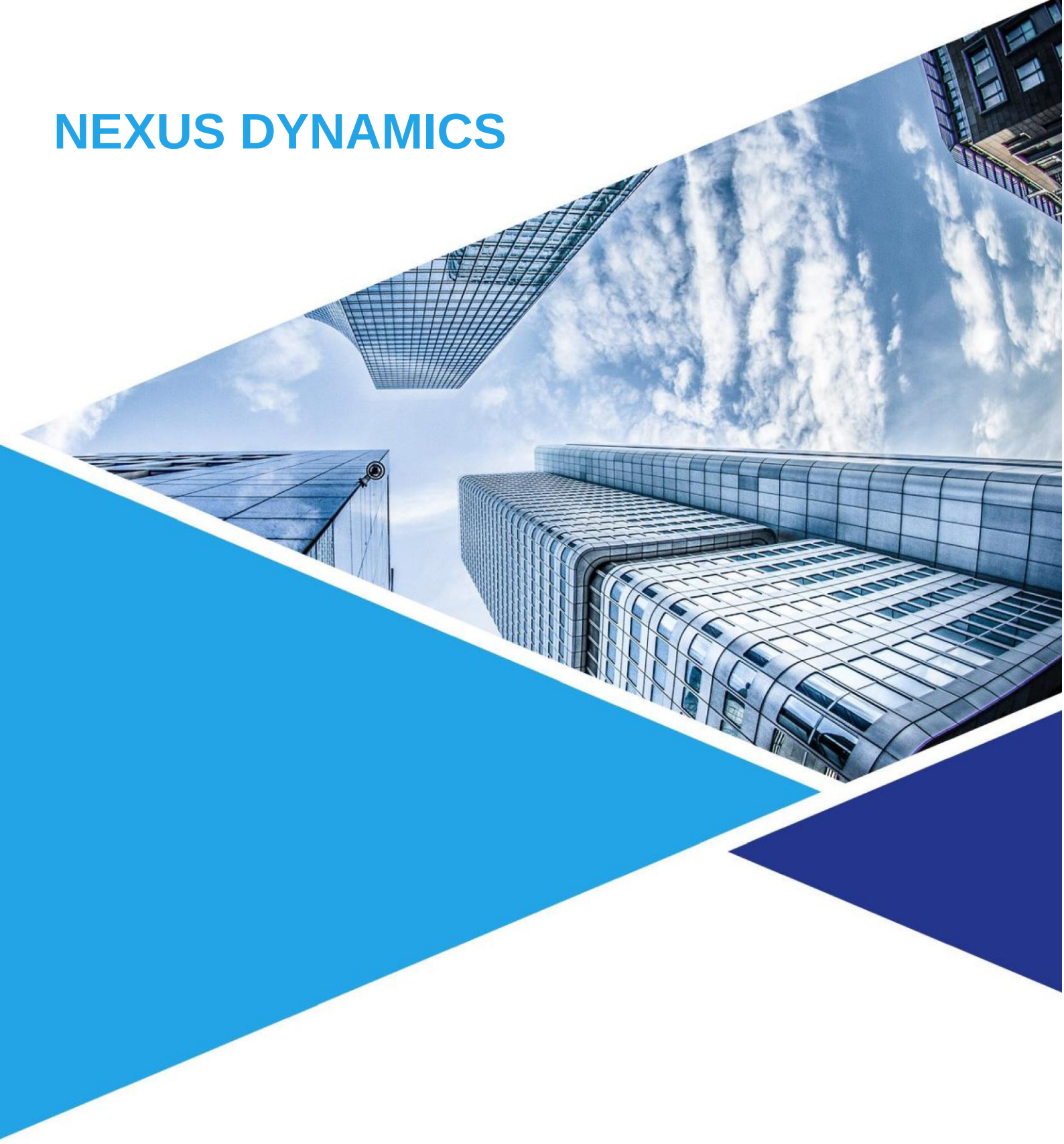
NEXUS DYNAMICS



THREAT INTELLIGENCE REPORT

CYBLACK 2025

TABLE OF CONTENT

EXECUTIVE SUMMARY 2
THREAT INTEL 4
INFORMATION GATHERING 6
RISK THREAT ASSESSMENT 8
THREAT PROFILE 12
TOP THREAT ACTOR RESEARCH 20
INDICATORS OF COMPROMISE (VIRUS TOTAL) 22
TTP MAPPING 25
MITRE ATT&CK FRAMEWORK 26
DEDUCTIONS FROM ANALYSIS FINDINGS 39
RECOMMENDATIONS 43
REFERENCES 45

EXECUTIVE SUMMARY

This report provides a thorough analysis of the cyber threat landscape facing Nexus Dynamics, a global technology corporation specializing in cloud computing, AI, and enterprise solutions. The analysis incorporates open-source intelligence, commercial threat intelligence, and security community information.

The report identifies significant vulnerabilities across Nexus Dynamics' infrastructure, including weaknesses in email security, certificate management, network security,

endpoint protection, and access controls. It also highlights risks associated with third-party vendors. The report assesses the potential threats posed by specific threat actors, including APT10, Clop, FIN12, LockBit, and BlackCat/ALPHV, with a particular focus on APT10 due to its history of targeting MSPs and technology companies.

The analysis provides a list of current vulnerabilities that could potentially impact Nexus Dynamics, drawing information from CVE databases and other credible security sources. Key mitigation strategies, like implementing patch management, enhancing access controls, and providing relevant cybersecurity training to staff, have also been provided.

Ultimately, this report aims to equip Nexus Dynamics with actionable intelligence to bolster its cybersecurity defenses and better protect its assets.

Threat Profile: APT10 (Detailed)

Overview: APT10, also known as Stone Panda, is a Chinese state-sponsored cyber espionage group active since 2009. They primarily target managed service providers (MSPs) and technology companies to steal intellectual property and sensitive data, aligning with China's strategic economic and technological objectives.

Motivation: Cyber espionage, intellectual property theft, economic advantage

Attribution: Strongly believed to be linked to China's Ministry of State Security (MSS)

Target Industries: Aerospace, Defense Contractors, Telecommunications, Healthcare and Pharmaceuticals, Managed Service Providers (MSPs), andHigh-Tech Manufacturing

Past Victims The report provides detailed information on past victims of APT 10:

-Fujitsu: Compromised systems led to unauthorized access to government and corporate data.

-T-Mobile: Extensive network reconnaissance and credential theft leading to data breaches.

-DXC Technology: Exploited vulnerabilities within their systems, allowing for data exfiltration and supply chain vulnerabilities.

-Hewlett Packard Enterprise (HPE): Infiltrated MSP infrastructure, accessing client data and sensitive information.

Why Nexus Dynamics is a Target:

-High-Value Information: Nexus Dynamics is a global leader that manages sensitive data and IT services for many large organizations.

-Supply Chain Leverage: As an MSP, Nexus Dynamics serves as a gateway to other organizations' networks, thus compromising them gives APT10 access to other victims.

-Strategic Goals: APT10's activities align with China's goals to boost its economic and technological advancement.

Indicators of Compromise (IOCs):

-Malware: LODEINFO, NOOPDOOR, PlugX, Poison Ivy, ChChes (Scorpion, Haymaker), EvilGrab, RedLeaves, Snugride, Uppercut Scanbox, custom backdoors.

-Tactics: Spear-phishing emails with malicious attachments, exploiting vulnerabilities in applications, detection evasion using web shells like China Chopper.

-Command and Control (C2): Dynamic domains and IP addresses to evade detection.

This report highlights critical vulnerabilities and the pressing need to address them to reduce the risk of exploitation by advanced threat actors like APT10. By strengthening defenses, particularly in areas like access controls, patch management, and employee training, Nexus Dynamics can better protect its systems, clients, and reputation. Cybersecurity is not a one-time effort but an ongoing commitment, and taking proactive steps now will help the company stay ahead of evolving threats while continuing to deliver trusted solutions to its global clients.

THREAT INTEL

Sources of cyber threat intelligence

The six (6) major sources of cyber threat intelligence to be used for information gathering for NEXUS DYNAMICS are as follows:

Open Source Intelligence (OSINT)

-Virus Total: is a source that automatically shares detected malware or previously analyzed suspicious files, domains, IPs, URLs, and other breaches with a security community.

-Open Threat Exchange (OTX): is a platform that enables worldwide sharing of threat intelligence from companies and researchers provided by **AlienVault.**

-CrowdSec

Commercial Threat Intelligence Services

-Cisco Talos: is a commercial threat intelligence, a composition of world-class researchers, analysts and engineers, working together to defend against known and emerging threats aiming to protect Cisco customers and the internet at large.

Cyber Security News and Forums

Reddit, Cisco Community, Palo Alto Live Community

Social Media

LinkedIn, Twitter/X

Intelligence Sharing Communities

-MISP Threat Sharing: Malware Information Sharing platform is a platform that curates, correlates, stores and shares security threats and IoCs in a structured format like STIX, OpenIoC.

-MITRE Att&ck

Government and Industry Threat Portals

-CISA (Cybersecurity and Infrastructure Security Agency): is an agency that is focused on enhancing cybersecurity posture, mitigating risks, and responding to cyber related incidents in the **(US)** nation and other sectors.
-NCSC (UK's National Cyber Security Center): NCSC expertly provides threat intelligence, guidance and incidence response capabilities to public and private sector organizations and also individuals therefore enhancing the cybersecurity resilience of the UK.

Threat intelligence tools

1. NMAP
2. TheHarvester
3. Maltego

4. Shodan
5. Intelligence X:
6. Any.run
7. Reckon/ng
8. WhoIs
9. DNS checker
10. Red HAWK

Suggestions for professional organizations

Here are a few suggestions for professional organization/Advisory groups that Nexus Dynamics can join to learn and exchange Threat intelligence News include:

1. **Cyber Oregon:** develops shared vision collaborating with other industries, private sector security practitioners, educational , law-enforcement and governmental institutions related to Oregon for the establishment of Cybersecurity Center of excellence across these sectors

2. **NCC- National Coordinating Center for Communications:** NCC comprises of many private sector companies and some federal government agencies collaborating in a trusted environment and routinely share critical information and advice to support National Security and Emergency preparedness communication mission of the NCC

3. **CSIA - Cyber, Space & Intelligence Association:** CSIA promotes an environment that facilitates the flow of ideas between security leaders in various organisations about cyber, space, and intelligence challenges and opportunities.

4. **ISF - Information Security Forum:** is a research, practical tools and guidance that address current security topics and are used by members to overcome Information Security challenges impacting their businesses.

5. **Space ISAC - Information Sharing and Analysis Center:** is a source of security information for the space industry. It facilitates collaboration in the industry and helps prepare and respond to vulnerabilities, incidents, and threats.

INFORMATION GATHERING

To identify and assess relevant cyber threats, vulnerabilities, and risks faced by Nexus Dynamics, providing actionable insights to strengthen the organization's security posture.

Overview of Nexus Dynamics

Nexus Dynamics is a globally recognized technology corporation specializing in cloud computing, artificial intelligence (AI), and enterprise solutions. The company provides innovative products and services that support industries ranging from finance to healthcare. Founded in 1911, Nexus Dynamics operates in over 170 countries, employing approximately 300,000 individuals worldwide. The company's extensive portfolio includes software development, consulting, and hardware solutions, making it a leader in technological advancement and innovation.

Headquarters: Nexus Dynamics is headquartered in Armonk, New York, with regional offices and innovation centers spread globally.

Locations:

Operations in over 170 countries with significant presence in North America, Europe, Asia, and South America.

19 research facilities spread across 12 laboratories on 6 continents.

Employees: Approximately 300,000 employees across various roles, including research, development, consulting, and technical support.

Social Media Presence: Nexus Dynamics maintains a robust online presence to engage stakeholders and promote its brand:

LinkedIn: ~10 million followers, focused on professional networking and thought leadership.

Twitter (X): ~2 million followers, providing updates on products, services, and events.

Facebook: ~1.5 million followers, engaging with a wider audience.

Instagram: ~500,000 followers, showcasing employee culture and innovation stories.

YouTube: ~1 million subscribers, offering webinars, tutorials, and promotional content.

Key Business Areas

Cloud Computing: Offering hybrid cloud platforms that integrate on-premise and cloud environments**.**

Artificial Intelligence (AI): Providing AI-powered tools to improve business insights and automate workflows.

Cybersecurity: Delivering end-to-end solutions to protect critical data and infrastructure from threats.

Consulting Services: Helping clients design and implement IT strategies tailored to their business goals.

IT Infrastructure

- Extensive use of hybrid cloud architecture.
- Integrated data centers for global operations.
- Partnerships with leading hardware and software providers. **Key Clients**

- Large financial institutions.
- Healthcare providers.
- Retail and e-commerce companies.
- Government agencies.

Threat Intelligence Findings

Category	**Findings**
Email	Legacy email systems in use, potential phishing susceptibility, lack of DMARC, SPF, DKIM configurations.
Certificates	Expired SSL/TLS certificates found on subdomains; some domains lack HTTPS.
Network	Open ports on critical servers; outdated software on edge devices.
Endpoint Security	Unpatched devices with known vulnerabilities; lack of endpoint detection and response (EDR) tools.
Access Control	Excessive administrative privileges; no multi-factor authentication (MFA) for sensitive applications.
Third-party Risks	Vendors with access to critical systems lack a validated security posture.

RISK THREAT ASSESSMENT

Category	**Threats**	**Vulnerabilities**	**Potential Risks**

Email	Phishing, business email compromise (BEC).	Legacy email systems and insufficient configurations.	Financial losses, reputational damage, compliance violations.
Certificates	Man-in-the-middle (MITM) attacks, data interception.	Expired or absent SSL/TLS certificates.	Unauthorized access to sensitive data and systems.
Network	Ransomware, unauthorized access.	Unpatched devices, missing endpoint tools.	Service disruptions due to ransomware or DoS attacks.
Endpoint Security	Malware propagation, insider threats.	Unpatched devices, missing endpoint tools.	Data theft through compromised endpoints.
Access Control	Credential theft, privilege escalation.	Excessive administrative privileges.	Unauthorized access to sensitive data and privilege abuse.
Third-party Risks	Supply chain attacks, vendor-induced breaches.	Weak vendor security controls.	Data theft through compromised vendors.

In Nexus Dynamics there is a system created called N-Force (X-Force) that is used to mitigate and record threats by cyber criminals. It is used to track the activities of all users in the company where it is meant to protect their data from being syphoned by unauthorized users. It was recorded in 2023 that the rise in the use of fake accounts by cybercriminals to accessing the system was 30% and 71% in the World's population.

Controls to Mitigate Risks

Category	Proposed Controls	Priority	Timeline for Remediation
Email	Implement DMARC, SPF, and DKIM; conduct phishing simulations; provide employee training.	High	2 months
Certificates	Regularly audit and renew SSL/TLS certificates; enforce HTTPS with modern TLS standards.	High	1 month
Network	Conduct regular vulnerability scans; patch outdated software; close unnecessary ports.	Medium	3 months
Endpoint Security	Deploy EDR tools; enforce patch management policies; implement anti-malware solutions.	High	3 months
Access Control	Enforce MFA for sensitive applications; implement role-based access control (RBAC).	High	2 months
Third-party Risks	Conduct vendor security assessments; require compliance with ISO 27001 or SOC 2 standards.	Medium	4 months

Recommendations

Email Security:

- Enforce DMARC, SPF, and DKIM protocols for email authentication.
- Conduct regular phishing awareness training and simulations for employees.
- Invest in advanced email filtering and threat detection tools.

Certificate Management:

- Implement automated SSL/TLS certificate monitoring and renewal systems.
- Mandate HTTPS for all web-facing applications and ensure strong encryption standards.

Network Security:

- Regularly conduct network vulnerability scans and penetration testing.
- Apply timely patches to address known vulnerabilities.
- Use network segmentation to isolate critical systems and minimize attack surfaces.

Endpoint Protection:

- Deploy endpoint detection and response (EDR) tools across all devices.
- Enforce strict patch management and software updates.
- Provide cybersecurity training tailored to endpoint threats.

Access Controls:

- Enforce multi-factor authentication (MFA) for all systems.
- Implement role-based access control (RBAC) to limit privileges.
- Conduct periodic access reviews to identify and rectify privilege creep.

Third-party Risk Management:

- Assess third-party vendors' security practices during onboarding and regularly thereafter.
- Require vendors to comply with industry standards such as ISO 27001.
- Monitor and restrict third-party access to critical systems.

Conclusion

The assessment reveals that Nexus Dynamics faces significant cybersecurity challenges, including vulnerabilities in email, certificate management, and endpoint security. Addressing these issues is critical to reducing exposure to phishing attacks, ransomware, and unauthorized access.

By implementing the recommended controls, Nexus Dynamics can significantly enhance its security posture. These measures will protect the organization's assets, maintain compliance, and safeguard its reputation. Continuous monitoring, periodic reviews, and staff training will ensure resilience against evolving threats and help foster a culture of security awareness.

THREAT PROFILE

Top 5 active threat Actors

1. **APT 10**

APT10 (Advanced Persistent Threat 10), also known as **Stone Panda** or **Cloud Hopper**, is a sophisticated cyber-espionage group believed to be linked to the Chinese government. The group has been active since at least **2009**, conducting extensive cyber-espionage campaigns targeting a wide range of industries worldwide, including technology, healthcare, manufacturing, and more. In **2016-2018**, APT10 carried out a large-scale campaign dubbed **Cloud Hopper** targeting **managed service providers (MSPs)**, including **NEXUS DYNAMICS**. MSPs provide outsourced IT and cloud services to many other organizations, making them high-value targets for attackers looking to gain access to the systems of their clients.

Key activities and impacts:

1. **Supply Chain Attack**: APT10 exploited NEXUS DYNAMICS's networks by infiltrating its MSP infrastructure. By compromising NEXUS DYNAMICS, the group could potentially access the networks of NEXUS DYNAMICS's customers.
2. **Data Theft**: APT10 harvested sensitive data, including intellectual property, trade secrets, and corporate information.
3. **Credential Harvesting**: The attackers stole user credentials, allowing them to maintain persistent access to systems.
4. **Malware Deployment**: The group used custom malware and sophisticated techniques to evade detection.

Why APT10 may target NEXUS DYNAMICS

1. **High-Value Information**: NEXUS DYNAMICS is a global technology leader managing sensitive data and IT services for many large organizations. Compromising NEXUS DYNAMICS allows attackers to access a treasure trove of intellectual property and sensitive customer information.
2. **Supply Chain Leverage**: As a Managed Service Provider, NEXUS DYNAMICS serves as a gateway to other organizations' networks. Attacking NEXUS DYNAMICS can lead to secondary compromises of its clients, multiplying the impact of the breach.
3. **Espionage and Economic Goals**: APT10's operations align with strategic objectives to boost China's economic and technological development. By stealing trade secrets and intellectual property, they aim to enhance China's competitiveness.

2. Clop

Why Clop May target NEXUS DYNAMICS

The **Clop ransomware group** strategically selects high-value targets to maximize financial gain and impact. NEXUS DYNAMICS, being a global leader in technology and IT services, presents an attractive target for several reasons:

1. **Data Value**

   NEXUS DYNAMICS manages sensitive data for numerous industries, including healthcare, finance, manufacturing, and government agencies. Breaching NEXUS DYNAMICS's systems or its managed service platforms could grant Clop access to:

   -Intellectual Property: Patents, proprietary technology, and innovative solutions.

-Customer Data: Client information from organizations relying on NEXUS DYNAMICS's services.

-Sensitive Files: Data that can be leveraged for extortion or sold on the dark web.

By targeting NEXUS DYNAMICS, Clop can gain data that holds immense value both monetarily and strategically.

2. **Supply Chain Leverage**

NEXUS DYNAMICS is a **Managed Service Provider (MSP)**, supporting thousands of organizations worldwide. Attacking NEXUS DYNAMICS offers:

-Indirect Access: Through NEXUS DYNAMICS, Clop can infiltrate the systems of its customers, amplifying the attack's reach.

-Broad Impact: A breach in NEXUS DYNAMICS's supply chain could affect critical infrastructure, healthcare services, and financial institutions, which increases the urgency for victims to pay ransoms.

3. **Reputation and Influence**

NEXUS DYNAMICS is a globally recognized brand. A successful attack on such a prominent company would:

-Enhance Clop's Reputation: Among cybercriminal circles, pulling off such an attack would bolster Clop's credibility and notoriety.

-Intimidate Future Victims: Demonstrating the ability to breach NEXUS DYNAMICS could make other organizations more likely to comply with ransom demands.

4. **Technological Dependency**

NEXUS DYNAMICS provides extensive cloud services, software, and infrastructure support. These platforms often become the backbone of many enterprises. Clop exploits this dependency by:

-Targeting Vulnerabilities: For example, vulnerabilities in file transfer tools like **MOVEit**, widely used by NEXUS DYNAMICS and other organizations. **-Creating Disruption**: Disabling critical IT infrastructure can halt business operations, pressuring victims to pay the ransom.

5. **Financial Capability**

NEXUS DYNAMICS's clients are typically large enterprises with the financial capacity to pay significant ransoms. Clop knows that:

-The cost of downtime and data recovery is often higher than the ransom itself.

-Targeting NEXUS DYNAMICS indirectly pressures multiple victims (NEXUS DYNAMICS and its clients) to comply.

6. **Exploitation of Third-Party Software**

Clop has a history of exploiting vulnerabilities in third-party applications like **MOVEit**. NEXUS DYNAMICS's reliance on such software for managing customer operations makes it an indirect target. By breaching these systems, Clop can:

-Sidestep Direct Defenses: Instead of breaching NEXUS DYNAMICS's core infrastructure, Clop targets less-secure third-party software integrated into NEXUS DYNAMICS's ecosystem.

-Widen the Attack Surface: Vulnerabilities in file transfer systems or cloud services affect NEXUS DYNAMICS and its customers simultaneously.

7. **Opportunity for Extortion**

   Clop employs **double-extortion tactics**, where it not only encrypts data but also threatens to leak it. This strategy is particularly effective against NEXUS DYNAMICS due to:

   -Sensitive Nature of Data: The exposure of trade secrets or customer data could harm NEXUS DYNAMICS's reputation.

   -Pressure to Protect Clients: NEXUS DYNAMICS would face pressure from its clients to resolve the issue quickly, potentially increasing the likelihood of ransom payment.

3. FIN 12

Why FIN12 may target NEXUS DYNAMICS

FIN12 is a ransomware group known for targeting high-value organizations to maximize financial gain. NEXUS DYNAMICS, being a global leader in technology and IT services, is an attractive target for several reasons:

1. **Valuable Data**

   NEXUS DYNAMICS handles sensitive data for various industries like healthcare, finance, and government. Targeting NEXUS DYNAMICS could give FIN12 access to:

   -Confidential client information.

   -Proprietary technologies and solutions.

   -Managed service data from companies relying on NEXUS DYNAMICS for critical operations.

This data could be used for extortion or sold to other cybercriminals.

2. **Likelihood of Ransom Payment**

   NEXUS DYNAMICS's clients are large organizations with the resources to pay significant ransoms. Many would pay to avoid the financial and reputational damage caused by downtime. NEXUS DYNAMICS's role as a trusted service provider would add pressure to resolve any disruption quickly, making ransom payment more likely.

3. **Impact on the Supply Chain**

NEXUS DYNAMICS supports thousands of businesses worldwide. An attack on NEXUS DYNAMICS wouldn't just affect them—it could also disrupt their clients' operations. This ripple effect increases the urgency for a resolution, benefiting FIN12's tactics.

4. **Reputation and Influence**

   NEXUS DYNAMICS's global prominence makes it a high-profile target. Successfully breaching NEXUS DYNAMICS would:

   -Boost FIN12's reputation in cybercriminal circles.

   -Serve as a warning to other potential victims, increasing the likelihood of future ransom payments.

4. LockBit

LockBit is a highly sophisticated ransomware group known for targeting high-value organizations across industries. It was first observed in **2019** and has since evolved into multiple versions (e.g., LockBit 2.0, LockBit 3.0). The group operates under a **Ransomware-as-a-Service (RaaS)** model, recruiting affiliates to execute attacks.

Motivations to Target NEXUS DYNAMICS:

1. **High-Value Data**

   NEXUS DYNAMICS manages sensitive data for numerous clients, including critical industries like finance, healthcare, and government. Stealing or encrypting

NEXUS DYNAMICS's data or its clients' data would give LockBit significant leverage for extortion.

2. **Global Reach and Supply Chain Impact**

   NEXUS DYNAMICS's global presence and role as a managed service provider (MSP) make it an ideal target for supply chain attacks. Breaching NEXUS DYNAMICS could indirectly compromise thousands of its clients, amplifying the impact of the attack.

3. **Reputation and Pressure**

   NEXUS DYNAMICS's status as a tech giant would attract attention to LockBit, bolstering its reputation in the cybercriminal ecosystem. Additionally, NEXUS DYNAMICS and its clients might feel pressured to pay quickly to avoid extended disruptions.

4. **Financial Capability**

   NEXUS DYNAMICS's clients are likely able to afford large ransom payments to recover their operations and protect their data, aligning with LockBit's financial goals.

Actors Behind LockBit

The group is believed to involve cybercriminals primarily from **Eastern Europe**, specifically **Russia**, as they avoid attacking organizations in the Commonwealth of Independent States (CIS). The actors are technically skilled and focus on exploiting vulnerabilities, social engineering, and insider threats.

5. BlackCat/ ALPHV

BlackCat, also known as ALPHV, emerged in **late 2021** as one of the first ransomware groups to use the **Rust programming language**, known for its speed and evasion capabilities. It also operates under the **RaaS model**, making it accessible to a network of affiliates.

Motivations to target NEXUS DYNAMICS

1. **Complex Infrastructure**

   NEXUS DYNAMICS's vast ecosystem, including cloud services, AI, and analytics platforms, provides numerous attack vectors. BlackCat is highly adaptive and capable of exploiting weaknesses in such environments.

2. **Double and Triple Extortion Tactics**

   BlackCat is known for its **multi-layered extortion tactics**, including:

   -Encrypting data.

   -Stealing data and threatening to leak it.

   -Targeting clients and partners if ransom demands are unmet.

   Targeting NEXUS DYNAMICS would allow BlackCat to apply these tactics to a massive pool of stakeholders, increasing the likelihood of a payout.

3. **Client Dependency on NEXUS DYNAMICS**

   Many organizations depend on NEXUS DYNAMICS for their critical IT operations. Disrupting these services would create significant operational and reputational damage, making ransom payments more appealing.

4. **Reputation and Notoriety**

   Attacking a high-profile company like NEXUS DYNAMICS would enhance BlackCat's visibility and credibility within the ransomware community, potentially attracting more affiliates to their RaaS platform.

Actors Behind BlackCat

The group is believed to include **former affiliates of other ransomware groups** like DarkSide and BlackMatter. Its origins point to **Eastern Europe** or **Russia**, and like LockBit, it avoids targeting organizations in CIS countries.

TOP THREAT ACTOR RESEARCH

Among the threat actors mentioned above, APT 10 presents a greater threat to Nexus Dynamics.

The APT 10 (Advanced Persistent Threat 10) also known as Stone Panda, menupass, Cloud Hopper, Bronze Riverside, ChessMaster, Cicada, Cloudhopper, MenuPass, MirrorFace, Purple Typhoon (formerly Potassium), and Stone Panda is a state-sponsored cyber threat actor widely associated with the Chinese government. This group has been active since 2009 and is known for conducting cyber-espionage campaigns on Managed Service Providers (MSPs) and technology-based companies, to steal intellectual property and confidential business information. Their operations are believed to support China's strategic objectives by acquiring sensitive data from various sectors.

1. **Name of company impacted:** Fujitsu

Industry Type: Information Technology

Revenue: $32.5 Billion (2024)

Number of Employees: Approximately 130,000

Brief description of the attack: APT10 compromised Fujitsu's systems, leading to unauthorized access to government and corporate data.

Impact of the attack: The attack resulted in data breaches affecting multiple clients and potential financial losses.

2. **Name of company impacted:** T-Mobile

Industry Type: Telecommunications

Revenue: $78.5Billion

Number of Employees: 67,000

Brief Description of the Attack: The attackers conducted extensive network reconnaissance and employed tools like modified versions of Mimikatz to steal credentials, facilitating lateral movement within the network.

Impact of the attack: Data breach, Operational Disruption, Reputational Damage

3. **Name of company impacted:** DXC Technology

Industry Type: Information Technology Services

Revenue: $13.2 billion

Number of Employees: Approximately 130,000

Brief Description of the attack: The attackers exploited vulnerabilities within these service providers to gain unauthorized access to their clients' systems.

Impact of the attack: Data Exfiltration, Supply chain Vulnerabilities, Operational Dysfunction.

4. **Name of company impacted:** Hewlett Packard Enterprise (HPE)

Industry Type: Information Technology

Revenue: $27.8 billion (2024)

Number of Employees: Approximately 60,000

Brief Description of the Attack: APT10 infiltrated HPE's managed service provider infrastructure, accessing client data and sensitive information.

Impact: The breach led to concerns over data security among HPE's clients and potential financial and reputational damage.

Given APT10's history of targeting technology companies and managed service providers, Nexus Dynamics could be a potential target due to its significant role in the IT industry. The group's focus on intellectual property theft and cyber espionage aligns with the type of data Nexus Dynamics handles, making it imperative for the company to implement cybersecurity measures to defend against such threats.

INDICATORS OF COMPROMISE (VIRUS TOTAL)

Indicators of compromise (IOCs) refer to data that indicates a system may have been infiltrated by a cyber threat. They provide cybersecurity incident response teams with crucial knowledge after a data breach for malware detection.

Some common IoCs associated with APT10's activities include:

Malware: LODEINFO, NOOPDOOR, PlugX, Poison Ivy, ChChes (Scorpion, Haymaker), EvilGrab, RedLeaves, Snugride, Uppercut Scanbox, and custom backdoors. APT10 is targeting Japanese enterprises using these malware families to obtain sensitive data from compromised hosts for a period of two to three years, all the while staying under the radar.

Tactics: Spear-phishing emails with malicious attachments, exploitation of vulnerabilities in applications, detection evasion, and the use of web shells like China Chopper.

Command and Control (C2) Infrastructure: Use of dynamic domains and IP addresses to communicate with compromised systems, evading detection.

IP Addresses: 45.66.217.106, 89.233.109.69, 45.77.12.212, 108.160.130.45, 207.148.97.235, 95.85.91.15, 64.176.214.51, 168.100.8.103, 45.76.222.130, 45.77.183.161, 207.148.90.45, 207.148.103.42

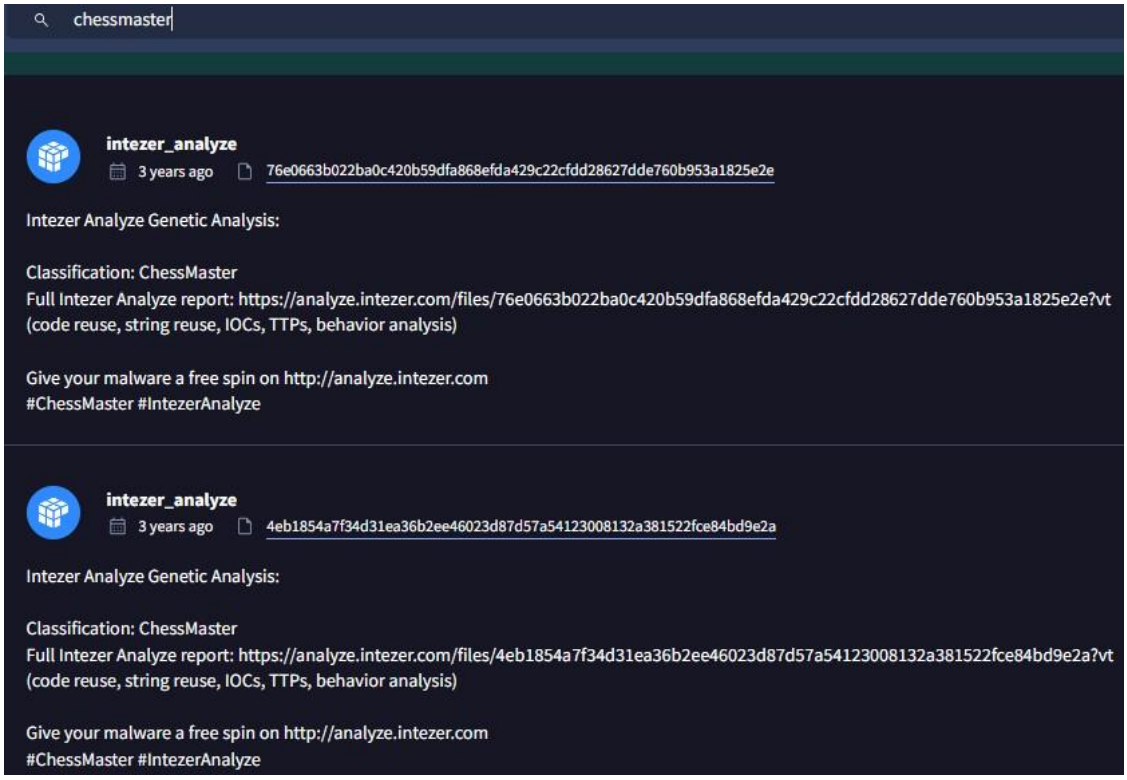
Open Source Tools: Mimikatz (Info Stealer), PowerSploit (Offensive security framework), Pwdump (Credential Dumper), Impacket (Networking tool), Quasar (RAT).

VIRUS TOTAL

APT10 frequently adapts its techniques, tools, and infrastructure to evade detection. As a result, older IOCs such as the malware and IP addresses, are no longer valid or useful.

Using Virus Total, a source that automatically shares detected malware or previously analyzed suspicious files and other breaches with a security community, the threat actor,

APT10, was found under the name “chessmaster”. The following information were revealed:



These 2 SHA-256 hashes (76e0663b022ba0c420b59dfa868efda429c22cfdd28627dde760b953a1825e2e) and (4eb1854a7f34d31ea36b2ee46023d87d57a54123008132a381522fce84bd9e2a) are hashes of files related to chessmaster threat group. They both contain links to full reports on the hashes including: Links are provided to the full reports on Intezer Analyze for both file hashes. These reports include: Code reuse (APT10 reuses code from known malware families), string reuse (APT10 uses repeated strings (e.g., commands, domains) in malware operations), extracts data like IPs, domains, file hashes, and registry keys for detection and exploits vulnerabilities and lateral movement). Both files were flagged as part of the ChessMaster malware family, they are connected to APT10's operations and are likely used for cyber-espionage campaigns.

76e0663b022ba0c420b59dfa868efda429c22cfdd28627dde760b953a1825e2e

Security vendors' analysis | Do you want to automate

Bkav Pro	W32.AIDetect.malware1	CrowdStrike Falcon	Win/malicious_confidence_90% (W)
McAfee-GW-Edition	RDN/pws-onlinegame.ck	Rising	Trojan.Generic@ML.80 (RDML:8P7UXxSF...
Sangfor Engine Zero	Trojan.Win32.Save.a	SecureAge	Malicious
Trellix (ENS)	RDN/pws-onlinegame.ck	Trellix (HX)	Generic.mg.ba50b146fb8432c4
TrendMicro-HouseCall	TROJ_GEN.R002H06KO21	Acronis (Static ML)	Undetected
Ad-Aware	Undetected	AhnLab-V3	Undetected

9 security vendors flagged the first hash file as malicious:

Bkav Pro: Windows-based malware

CrowdStrike Falcon: Malicious Windows File

McAfee-GW-Edition: Password Stealing Trojan

Rising: Trojan

Sangfor Engine Zero: Windows-based Trojan

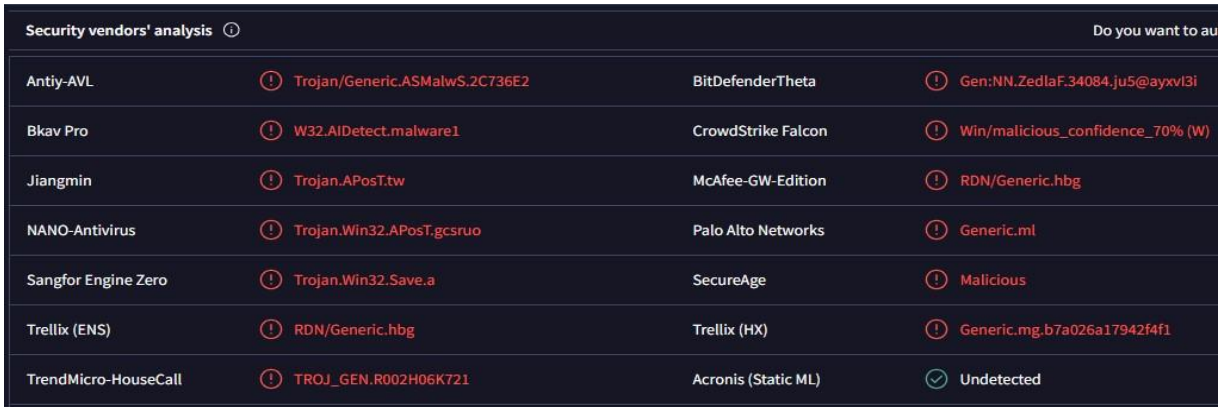
SecureAge: Malicious

Trellix (ENS): Malware

Trellix (HX): Malware

TrendMicro-HouseCall: Trojan

This hash file is highly associated with password stealing, credential harvesting, malware, and other malicious activities.



Security vendors' analysis | Do you want to au

Antiy-AVL	Trojan/Generic.ASMalwS.2C736E2	BitDefenderTheta	Gen:NN.ZedlaF.34084.ju5@ayxvI3i
Bkav Pro	W32.AIDetect.malware1	CrowdStrike Falcon	Win/malicious_confidence_70% (W)
Jiangmin	Trojan.APosT.tw	McAfee-GW-Edition	RDN/Generic.hbg
NANO-Antivirus	Trojan.Win32.APosT.gcsruo	Palo Alto Networks	Generic.ml
Sangfor Engine Zero	Trojan.Win32.Save.a	SecureAge	Malicious
Trellix (ENS)	RDN/Generic.hbg	Trellix (HX)	Generic.mg.b7a026a17942f4f1
TrendMicro-HouseCall	TROJ_GEN.R002H06K721	Acronis (Static ML)	Undetected

13 security vendors flagged the second hash file as malicious.

Palo Alto Networks: malware **Antiy-AVL:** Trojan

Nano-Antivirus: Trojan **Jiangmin:** Trojan

Several vendors classified the file as a "Trojan," a type of malware that disguises itself as legitimate software but performs harmful activities, such as stealing data, enabling unauthorized access, and delivering additional malicious payloads. The hash files act as critical IOCs by uniquely identifying and linking malware to APT10's activities and play a pivotal role in threat detection, response, and proactive defense against APT10's nation-state-sponsored cyberespionage activities.

TTP MAPPING

This is a detailed overview of APT10's operational tactics, mapped to the MITRE ATT&CK framework across the 14 tactics, and includes an explanation of their methods at each stage of the attack lifecycle. By understanding APT10's Tactics, Techniques, and Procedures based on the MITRE ATT&CK Framework, Nexus Dynamics can identify its attack patterns and strengthen its cybersecurity defenses.

The MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework is used for various security analyses, such as intrusion detection, threat hunting, security engineering, and risk management. It aids security analysts in performing analyses while following industry-standard procedures and defense strategies. The framework is highly useful for attack diagnosis and should enhance the understanding of threat actors' behaviors and techniques.

During the **reconnaissance** stage, the attacker gathers information to plan and carry out future operations to accomplish an attack. APT10 initiates its campaigns by profiling targets, identifying exposed assets, and leveraging public data sources to tailor spear-phishing emails

Resource Development entails the attacker establishing resources to support the operations being planned. APT10 establishes infrastructure such as command-and-control (C2) servers and registers domains for phishing campaigns.

Initial access describes the attacker attempting to gain initial access to the target environment. APT10 sends emails with malicious attachments, using stolen credentials and vulnerabilities to gain unauthorized access.

Execution includes the attacker running malicious code on the system. APT10 schedules and executes malware payloads to compromise systems, using decoy files to avoid suspicion.

Persistence is characterized by the attacker trying to maintain access to the system or environment. APT10 maintains access even after the initial compromise is detected by modifying registry keys.

Privilege escalation occurs when the attacker is trying to gain higher-level permissions and elevate their access to the target system. APT10 uses stolen credentials and

software vulnerabilities to escalate privileges, obtaining administrative rights to maximize control over targeted systems.

Defense evasion is where the attacker avoids detection throughout their compromise of the system. APT10 encrypts malware and deactivates antivirus or monitoring systems to avoid detection.

Credential access describes the stage where the attacker tries to steal credentials to gain access to the system. APT10 extracts credentials from memory, repeating login attempts to gain access to accounts.

Discovery explains the attacker trying to gain more knowledge about the system and its internal environment. APT10 maps out the victim's network and identifies shared resources and valuable data.

During the **Lateral movement** stage, the attacker enters and moves through the internal environment of the system. APT10 exploits RDP to move laterally across systems and uses hash values of passwords to access sensitive data.

Collection describes the attacker gathering information relevant to the attacker's aim and objective. APT10 gathers data, such as credentials, intellectual property, sensitive business data, and personal information from shared drives or databases.

Command and Control includes the attacker trying to communicate with the system to control and operate the system. APT10 utilizes HTTP/HTTPS for communication to blend with normal traffic to exfiltrate data and receive instructions.

The **exfiltration** stage entails the attacker trying to steal data from the compromised system. APT10 extracts sensitive data via encrypted C2 channels, ensuring it is not detected by monitoring systems.

Impact includes the attacker trying to manipulate and destroy the system and its data. APT10 encrypts files to disrupt operations and deletes data to inflict financial losses and reputational damage.

The mapping below demonstrates sophisticated TTPs used by APT 10, based on the MITRE ATT&CK matrix across the 14 tactics.

MITRE ATT&CK FRAMEWORK

TACTIC	TECHNIQUE	MITRE ID	DESCRIPTION
Reconnaissance	—----------	—----------	—----------

Resource Development	Acquire Infrastructure: Domains	T1583.001	APT10 acquires domains that can be used during targeting.
	Obtain Capabilities: Tool	T1588.002	APT10 may buy and/or steal capabilities that can be used during targeting, rather than developing their own capabilities in-house.
Initial Access	Exploit Public-Facing Application	T1190	APT10 may attempt to exploit a weakness in an Internet-facing host or system to initially access a network.
	Phishing: Spearphishing Attachment	T1566.001	APT10 may send spearphishing emails with a malicious attachment in an attempt to gain access to victim systems.
	Trusted Relationship	T1199	APT10 may breach or otherwise leverage organizations that have access to intended victims.
Execution	Command and Scripting Interpreter: PowerShell Command and Scripting Interpreter: Windows Command Shell	T1059.001 T1059.003	APT10 may abuse PowerShell commands and scripts for execution. APT10 may abuse the Windows command shell for execution.
	Native API	T1106	APT10 may interact with the native OS application programming interface (API) to execute behaviors.
	Scheduled Task/Job: Scheduled Task	T1053.005	APT10 may abuse task scheduling functionality to facilitate initial or recurring execution of malicious code.

	User Execution: Malicious File	T1204.002	APT10 may rely upon specific actions by a user in order to gain execution. Users may be subjected to social engineering to get them to execute malicious code.
	Windows Management Instrumentation	T1047	APT10 may abuse Windows Management Instrumentation (WMI) to execute malicious commands and payloads.
Persistence	Hijack Execution Flow: DLL Search Order Hijacking Hijack Execution Flow: DLL Side-Loading	T1574.001 T1574.002	APT10 may execute their own malicious payloads by hijacking the search order used to load DLLs. APT10 may execute their own malicious payloads by hijacking the way operating systems run programs.
	Scheduled Task/Job: Scheduled Task	T1053.005	APT10 may abuse task scheduling functionality to facilitate initial or recurring execution of malicious code.
	Valid Accounts	T1078	APT10 may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

Privilege Escalation	Hijack Execution Flow: DLL Search Order Hijacking Hijack Execution Flow: DLL Side-Loading	T1574.001 T1574.002	APT10 may execute their own malicious payloads by hijacking the search order used to load DLLs. APT10 may execute their own malicious payloads by hijacking the way operating systems run programs.
	Process Injection: Process Hollowing	T1055.012	APT10 may inject malicious code into suspended and hollowed processes in order to evade process-based defenses.
	Scheduled Task/Job: Scheduled Task	T1053.005	APT10 may abuse task scheduling functionality to facilitate initial or recurring execution of malicious code.
	Valid Accounts	T1078	APT10 may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.
Defense Evasion	Deobfuscate/Decode Files or Information	T1140	APT10 may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis.

	Hijack Execution Flow: DLL Search Order Hijacking Hijack Execution Flow: DLL Side-Loading	T1574.001 T1574.002	APT10 may execute their own malicious payloads by hijacking the search order used to load DLLs. APT10 may execute their own malicious payloads by hijacking the way operating systems run programs.
	Indicator Removal: Clear Command History Indicator Removal: File Deletion	T1070.003 T1070.004	In addition to clearing system logs, an APT10 may clear the command history of a compromised account to conceal the actions undertaken during an intrusion. APT10 may delete or modify artifacts generated within systems to remove evidence of their presence or hinder defenses.

	Masquerading Rename System Utilities Match Legitimate Name or Location	T1036 T1036.003 T1036.005	APT10 may attempt to manipulate features of their artifacts to make them appear legitimate or benign to users and/or security tools. APT10 may rename legitimate system utilities to try to evade security mechanisms concerning the usage of those utilities. APT10 may match or approximate the name or location of legitimate files or resources when naming/placing them.

	Obfuscated Files or Information: Encrypted/Encoded File	T1027.013	APT10 may attempt to make an executable or file difficult to discover or analyze by encrypting, encoding, or otherwise obfuscating its contents on the system or in transit.
	Process Injection: Process Hollowing	T1055.012	APT10 may inject malicious code into suspended and hollowed processes in order to evade process-based defenses.
	Subvert Trust Controls: Code Signing	T1553.002	APT10 may undermine security controls that will either warn users of untrusted activity or prevent execution of untrusted programs.

	System Binary Proxy Execution: InstallUtil	T1218.004	APT10 may bypass process and/or signature-based defenses by proxying execution of malicious content with signed, or otherwise trusted, binaries.
	Valid Accounts	T1078	APT10 may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.
Credential Access	OS Credential Dumping: Security Account Manager	T1003.002	APT10 may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password
	OS Credential Dumping: NTDS	T1003.003	APT10 may attempt to access or create a copy of the Active Directory domain database in order to steal credential information, as well as obtain other information about domain members such as devices, users, and access rights
	OS Credential Dump ing:SLA Secrets	T1003.004	APT10 may attempt to access or create a copy of the Active Directory domain database in order to steal credential information, as well as obtain other information about domain members such as devices, users, and access rights.

	Input Capture: Keylogging	T1056.001	APT10 may log user keystrokes to intercept credentials as the user types them
Discovery	Account Discovery: Domain Account	T1087.002	APT10 Adversaries may attempt to get a listing of valid accounts, usernames, or email addresses on a system or within a compromised environment
	File and Directory Discovery	T1083	APT10 may enumerate files and directories or may search in specific locations of a host or network share for certain information within a file system
	Network Service Discovery	T1046	APT10 may attempt to get a listing of services running on remote hosts and local network infrastructure devices, including those that may be vulnerable to remote software exploitation
	Remote System Discovery	T1018	APT10 may attempt to get a listing of other systems by IP address, hostname, or other
			logical identifier on a network that may be used for Lateral Movement from the current system

	System Network Configuration Discovery	T1016	APT10 may look for details about the network configuration and settings, such as IP and/or MAC addresses, of systems they access or through information discovery of remote systems
	System Network Connections Discovery	T1049	APT10 may attempt to get a listing of network connections to or from the compromised system they are currently accessing or from remote systems by querying for information over the network
Lateral Movement	Exploitation of Remote Services	T1210	APT10 may exploit remote services to gain unauthorized access to internal systems once inside of a network
	Remote Services: Remote Desktop Protocol	T1021.001	APT10 may use Valid Accounts to log into a computer using the Remote Desktop Protocol (RDP)
	Remote Services: SSH	T1021.004	APT10 may use Valid Accounts to log into a service that accepts remote connections, such as telnet, SSH, and VNC
Collection	Archive Collected Data	T1560	APT10 may compress and/or encrypt data that is collected prior to exfiltration. Compressing the data can help to obfuscate the collected data and minimize the amount of data sent over the

			network
	Archive via Utility	T1560.001	APT10 may use utilities to compress and/or encrypt collected data prior to exfiltration.
	Automated Collection	T1119	Once established within a system or network, an adversary may use automated techniques for collecting internal data
	Data from Local System	T1005	APT10 may search local system sources, such as file systems and configuration files or local databases, to find files of interest and sensitive data prior to Exfiltration
	Data from Network Shared Drive	T1039	APT10 may search network shares on computers they have compromised to find files of interest.
	Data Staged: Local Data Staging Data Staged: Remote Data Staging	T1074.001 T1074.002	APT10 may stage collected data in a central location or directory on the local system prior to Exfiltration. APT10 may stage collected data in a central location or directory prior to Exfiltration. Data may be kept in separate files or combined into one file through techniques such as Archive Collected Data
	Input Capture: Keylogging	T1056.001	APT10 may log user keystrokes to intercept credentials as the user types them

Command and Control	Dynamic Resolution: Fast Flux DNS	T1568.001	APT10 may use Fast Flux DNS to hide a command and control channel behind an array of rapidly changing IP addresses linked to a single domain
			resolution
	Ingress Tool Transfer	T1105	APT10 may transfer tools or other files from an external system into a compromised environment
	Proxy: External Proxy	T1090.002	APT10 may use a connection proxy to direct network traffic between systems or act as an intermediary for network communications to a command and control server to avoid direct connections to their infrastructure
Exfiltration	—----------	—----------	—----------
Impact	—----------	—----------	—----------

Screenshots from the Mitre Att&ck website:

Techniques Used

Domain	ID		Name	Use
Enterprise	T1087	.002	Account Discovery: Domain Account	menuPass has used the Microsoft administration tool csvde.exe to export Active Directory data.[12]
Enterprise	T1583	.001	Acquire Infrastructure: Domains	menuPass has registered malicious domains for use in intrusion campaigns.[1][2]
Enterprise	T1560		Archive Collected Data	menuPass has encrypted files and information before exfiltration.[1][2]
		.001	Archive via Utility	menuPass has compressed files before exfiltration using TAR and RAR.[6][12][8]
Enterprise	T1119		Automated Collection	menuPass has used the Csvde tool to collect Active Directory files and data.[8]
Enterprise	T1059	.001	Command and Scripting Interpreter: PowerShell	menuPass uses PowerSploit to inject shellcode into PowerShell.[12][8]
		.003	Command and Scripting Interpreter: Windows Command Shell	menuPass executes commands using a command-line interface and reverse shell. The group has used a modified version of pentesting script wmiexec.vbs to execute commands.[6][12][13][10] menuPass has used malicious macros embedded inside Office documents to execute files.[9][10]
Enterprise	T1005		Data from Local System	menuPass has collected various files from the compromised computers.[1][8]
Enterprise	T1039		Data from Network Shared Drive	menuPass has collected data from remote systems by mounting network shares with `net use` and using Robocopy to transfer data.[6]
Enterprise	T1074	.001	Data Staged: Local Data Staging	menuPass stages data prior to exfiltration in multi-part archives, often saved in the Recycle Bin.[6]
		.002	Data Staged: Remote Data Staging	menuPass has staged data on remote MSP systems or other victim networks prior to exfiltration.[6][8]
Enterprise	T1140		Deobfuscate/Decode Files or Information	menuPass has used certutil in a macro to decode base64-encoded content contained in a dropper document attached to an email. The group has also used `certutil -decode` to decode files on the victim's machine when dropping UPPERCUT.[9][10]
Enterprise	T1568	.001	Dynamic Resolution: Fast Flux DNS	menuPass has used dynamic DNS service providers to host malicious domains.[2]
Enterprise	T1190		Exploit Public-Facing Application	menuPass has leveraged vulnerabilities in Pulse Secure VPNs to hijack sessions.[14]
Enterprise	T1210		Exploitation of Remote Services	menuPass has used tools to exploit the ZeroLogon vulnerability (CVE-2020-1472).[8]
Enterprise	T1083		File and Directory Discovery	menuPass has searched compromised systems for folders of interest including those related to HR, audit and expense, and meeting memos.[8]
Enterprise	T1574	.001	Hijack Execution Flow: DLL Search Order Hijacking	menuPass has used DLL search order hijacking.[6]
		.002	Hijack Execution Flow: DLL Side-Loading	menuPass has used DLL side-loading to launch versions of Mimikatz and PwDump6 as well as UPPERCUT.[12][10][8]
Enterprise	T1070	.003	Indicator Removal: Clear Command History	menuPass has used Wevtutil to remove PowerShell execution logs.[14]
		.004	Indicator Removal: File Deletion	A menuPass macro deletes files after it has decoded and decompressed them.[9][2]
Enterprise	T1105		Ingress Tool Transfer	menuPass has installed updates and new malware on victims.[6][2]
Enterprise	T1056	.001	Input Capture: Keylogging	menuPass has used key loggers to steal usernames and passwords.[2]
Enterprise	T1036		Masquerading	menuPass has used esentutl to change file extensions to their true type that were masquerading as .txt files.[10]
		.003	Rename System Utilities	menuPass has renamed certutil and moved it to a different location on the system to avoid detection based on use of the tool.[10]
		.005	Match Legitimate Name or Location	menuPass has been seen changing malicious files to appear legitimate.[2]

Enterprise	T1106		Native API	menuPass has used native APIs including `GetModuleFileName`, `lstrcat`, `CreateFile`, and `ReadFile`.[8]
Enterprise	T1046		Network Service Discovery	menuPass has used tcping.exe, similar to Ping, to probe port status on systems of interest.[12]
Enterprise	T1027	.013	Obfuscated Files or Information: Encrypted/Encoded File	menuPass has encoded strings in its malware with base64 as well as with a simple, single-byte XOR obfuscation using key 0x40.[9][10][8]
Enterprise	T1588	.002	Obtain Capabilities: Tool	menuPass has used and modified open-source tools like Impacket, Mimikatz, and pwdump.[12]
Enterprise	T1003	.002	OS Credential Dumping: Security Account Manager	menuPass has used a modified version of pentesting tools wmiexec.vbs and secretsdump.py to dump credentials.[12][13]
		.003	OS Credential Dumping: NTDS	menuPass has used Ntdsutil to dump credentials.[8]
		.004	OS Credential Dumping: LSA Secrets	menuPass has used a modified version of pentesting tools wmiexec.vbs and secretsdump.py to dump credentials.[12][13]
Enterprise	T1566	.001	Phishing: Spearphishing Attachment	menuPass has sent malicious Office documents via email as part of spearphishing campaigns as well as executables disguised as documents.[12][7][10][2]
Enterprise	T1055	.012	Process Injection: Process Hollowing	menuPass has used process hollowing in iexplore.exe to load the RedLeaves implant.[9]
Enterprise	T1090	.002	Proxy: External Proxy	menuPass has used a global service provider's IP as a proxy for C2 traffic from a victim.[7][10]
Enterprise	T1021	.001	Remote Services: Remote Desktop Protocol	menuPass has used RDP connections to move across the victim network.[6][2]
		.004	Remote Services: SSH	menuPass has used Putty Secure Copy Client (PSCP) to transfer data.[6]
Enterprise	T1018		Remote System Discovery	menuPass uses scripts to enumerate IP ranges on the victim network. menuPass has also issued the command `net view /domain` to a PlugX implant to gather information about remote systems on the network.[12][7]
Enterprise	T1053	.005	Scheduled Task/Job: Scheduled Task	menuPass has used a script (atexec.py) to execute a command on a target machine via Task Scheduler.[12]
Enterprise	T1553	.002	Subvert Trust Controls: Code Signing	menuPass has resized and added data to the certificate table to enable the signing of modified files with legitimate signatures.[14]
Enterprise	T1218	.004	System Binary Proxy Execution: InstallUtil	menuPass has used `InstallUtil.exe` to execute malicious software.[12]
Enterprise	T1016		System Network Configuration Discovery	menuPass has used several tools to scan for open NetBIOS nameservers and enumerate NetBIOS sessions.[12]
Enterprise	T1049		System Network Connections Discovery	menuPass has used `net use` to conduct connectivity checks to machines.[6]
Enterprise	T1199		Trusted Relationship	menuPass has used legitimate access granted to Managed Service Providers in order to access victims of interest.[12][7][8][1][2]
Enterprise	T1204	.002	User Execution: Malicious File	menuPass has attempted to get victims to open malicious files such as Windows Shortcuts (.lnk) and/or Microsoft Office documents, sent via email as part of spearphishing campaigns.[12][7][9][10][2]
Enterprise	T1078		Valid Accounts	menuPass has used valid accounts including shared between Managed Service Providers and clients to move between the two environments.[6][8][2][14]
Enterprise	T1047		Windows Management Instrumentation	menuPass has used a modified version of pentesting script wmiexec.vbs, which logs into a remote machine using WMI.[12][13][8]

DEDUCTIONS FROM ANALYSIS FINDINGS

It has been established that Nexus Dynamics is a global technology and consulting company with extensive operations in critical industries such as cloud computing, AI, quantum computing, and cybersecurity. Nexus Dynamics offers: -hybrid cloud platforms that integrate on-premise and cloud environments

-AI-powered tools to improve business insights and automate workflows.

-end-to-end cybersecurity solutions to protect critical data and infrastructure from threats.

-helps clients design and implement IT strategies tailored to their business goals.

Key Clients: Large financial institutions, healthcare providers, retail and e-commerce companies, and government agencies.

Risk assessment analysis findings

Analysis carried out using a risk assessment table reveals that Nexus Dynamics faces significant cybersecurity challenges, including email, certificate management, and endpoint security vulnerabilities, and is highly exposed to phishing attacks, ransomware, and unauthorized access. The vulnerabilities with high priority include:

Email Security: Phishing and Business Email Compromise (BEC) are significant risks targeting legacy email systems and can lead to financial losses, reputational damage, and compliance violations.

Expired Certificates: Man-in-the-middle (MITM) attacks arise from expired or absent SSL/TLS certificates, enabling unauthorized access to sensitive systems and data.

Endpoint Security: Malware and insider threats are enabled by unpatched devices and a lack of endpoint security tools, which can lead to data theft and compromise.

Access Control: Credential theft and privilege escalation due to excessive administrative privileges are key risks that can lead to unauthorized access to sensitive data, and privilege abuse may occur.

Conclusion

Nexus Dynamic faces critical cybersecurity vulnerabilities across email, certificates, networks, endpoint security, access control, and third-party risks. High-priority risks such as phishing, certificate expiration, and endpoint vulnerabilities require immediate action. Network vulnerabilities and third-party risks are medium priority and must also be addressed to ensure a comprehensive security posture. The risk assessment reflects that Nexus Dynamics currently has gaps in its security framework, leaving them exposed to phishing, ransomware, unauthorized access, and supply chain attacks.

Threat profile and vulnerability analysis findings

APT10, Clop, LockBit, FIN12, and BlackCat have been identified as threat actors Nexus Dynamics should be wary of, especially with these common attack patterns: supply chain vulnerabilities, data exploitation, ransomware extortion, and reputation destruction.

Motivations and capabilities:

Economic Gain: Clop, LockBit, FIN12, and BlackCat are financially motivated, seeking ransoms or selling data for profit.

State-sponsored espionage: APT10 is politically motivated, conducting espionage to advance national economic and strategic goals.

Technical Sophistication: Using advanced techniques, such as exploiting third-party software vulnerabilities (e.g., MOVEit), evading detection, and leveraging advanced programming languages, makes these groups highly effective.

APT10 emerging as the top threat actor poses the following **threats** to Nexus Dynamics:

Espionage: APT10 is a Chinese state-sponsored group to steal intellectual property and sensitive information, and Nexus Dynamics invests heavily in research and development, particularly in cutting-edge technologies. APT10 could target Nexus Dynamics to gain strategic technological advancements for state interests, undermining Nexus Dynamic's competitive advantage.

Supply Chain Attacks: APT10 has a history of targeting IT service providers (like Managed Service Providers—MSPs) to infiltrate their client networks through the supply

chain. An attack on Nexus Dynamic's infrastructure could compromise client systems and lead to reputational damage and financial liability.

Nexus Dynamic's Global Operations: Nexus Dynamics operates globally, and APT10 has a history of targeting enterprises in Europe, the Americas, and Asia. Its focus on multinational corporations means Nexus Dynamic's global infrastructure could be a high-value target.

Nexus Dynamic's Reputation and Trust: Nexus Dynamic's core business revolves around providing secure IT solutions to its clients and safeguarding sensitive data for several businesses. A successful attack by APT10 would not only lead to financial losses but could erode client trust, severely damaging Nexus Dynamic's brand as a leader in cybersecurity and IT solutions.

Nexus Dynamics is an attractive target due to its critical role in managing sensitive data, supporting critical industries, and its global prominence. This makes breaches in its ecosystem capable of causing widespread disruptions, impacting not only the organization but also its clients.

IOC and Mitre att&ck analysis findings

APT10, also known as Stone Panda and multiple aliases, is a state-sponsored Chinese cyber-espionage group active since 2009, targeting Managed Service Providers (MSPs) and technology companies to steal intellectual property and confidential business data, aligned with China's strategic objectives to acquire sensitive data across industries.

The following organizations have been impacted by APT10:

Fujitsu: Unauthorized access led to government and corporate data breaches, causing reputational and financial damage.

T-Mobile: Data breaches and operational disruptions due to stolen credentials and network reconnaissance.

DXC Technology: Exploited vulnerabilities caused supply chain risks and operational dysfunction.

Hewlett Packard Enterprise: Infiltration of infrastructure led to data exfiltration, client concerns, and reputational harm.

These organizations operate within the IT and technology sectors and were impacted by unauthorized access, exploited vulnerabilities, and data exfiltration. These incidents highlight patterns and characteristics that align closely with Nexus Dynamics' profile and further reinforce its susceptibility to being targeted by APT10.

Indicators of Compromise (IOCs):

Malware: APT10 employs a variety of malware (PlugX, Poison Ivy, RedLeaves) for stealth and data exfiltration.

Tactics: Spear-phishing, exploitation of vulnerabilities, and detection evasion.

C2 Infrastructure: Use of dynamic domains and IP addresses to maintain communication with compromised systems.

Tools: Mimikatz, PowerSploit, and Quasar RAT for credential theft, lateral movement, and system compromise.

IP Addresses: 45.66.217.106, 89.233.109.69, 45.77.12.212, 108.160.130.45, 207.148.97.235, 95.85.91.15, 64.176.214.51, 168.100.8.103, 45.76.222.130, 45.77.183.161, 207.148.90.45, 207.148.103.42

These are IP addresses flagged for involvement in phishing and credential harvesting; APT10 has been active over the years by frequently changing its IP address to consistently avoid detection over time.

VirusTotal Results:

Hashes: SHA-256 hashes linked to malicious files, specifically related to the ChessMaster malware family.

Malware hashes flagged as Trojans, highly associated with credential theft, unauthorized access, and cyber espionage activities were linked to APT10 operations under the “ChessMaster” pseudo name.

Several vendors classified the has files as a "Trojan ,highly associated with password stealing, credential harvesting, malware, and other malicious activities.

Mitre Att&ck Framework:

The mitre att&ck framework helps to highlight APT10's capabilities across various stages, revealing their methods used to achieve their objectives, including reconnaissance, initial access, persistence, privilege escalation, defense evasion, credential access, discovery, lateral movement, collection, and command and control (C2).

Key Findings:

-APT10 has a strong ability to adapt and leverage sophisticated approaches tailored to their targets.

-APT10 focuses on collecting sensitive data and maintaining long-term access by leveraging valid accounts, and utilizing encrypted or obfuscated files.

-APT10 can avoid detection from monitoring systems by using defense evasion techniques such as masquerading, clearing logs, and DLL hijacking.

-APT10 is highly known for their extensive use of reconnaissance, credential theft, and advanced lateral movement techniques.

Conclusion

After mapping APT10s techniques to the 14 mitre att&ck tactics, it has been revealed that APT10s attack pattern is:

1. Exploiting weak entry points

2. Executing malicious payloads

3. Evasion tactics

4. Long-term persistence

5. Data collection

RECOMMENDATIONS

1. Email Security

We would recommend that in the Nexus Dynamics organization one would;

-Enhance email authentication: Implement **DMARC** (an email security protocol that helps prevent email spoofing), **DKIM** (a protocol that verifies the authenticity of emails), and **SPF** (an email authentication protocol that helps prevent spam and phishing attacks) protocols to authenticate email senders and prevent spoofing.

-Strengthen email filtering: Deploy advanced email filtering systems to proactively block phishing attempts and malicious attachments.

-Enhance employee awareness: Conduct regular phishing simulations and training to empower employees to identify and report suspicious emails.

-Implement a secure email gateway: Utilize a secure email gateway to monitor and protect incoming and outgoing email traffic.

2. Social Media Security

Unintentional exposure of sensitive information through employee activity in Nexus Dynamics for the social media accounts presents a significant risk such as;

-Establish clear social media guidelines: Develop and enforce a comprehensive social media policy outlining acceptable sharing practices for employees.

-Proactively monitor social media: To monitor Nexus Dynamics social media accounts using tools like ZeroFox or Brandwatch to detect impersonation or malicious activity. **-**

Strengthen account security: Implement multi-factor authentication (MFA) for all corporate social media accounts.

-Educate employees on responsible social media use: Train employees on the risks of sharing sensitive information or locations online.

3. Certificate Management

Misconfigured, expired, or weak SSL/TLS certificates can expose websites in Nexus Dynamics to attacks like man-in-the-middle (MITM) intrusions.

-Automate certificate management: Utilize tools like Venafi, Let's Encrypt, or DigiCert to automate certificate issuance and renewal.

-Enforce strong encryption standards: Ensure TLS 1.2 or TLS 1.3 is enabled across all public-facing websites and APIs.

-Conduct regular security assessments: Perform regular certificate audits to identify and address misconfigurations or vulnerabilities.

-Leverage certificate transparency logs: Utilize certificate transparency logs to detect unauthorized certificate issuance.

4. Web Application Security

Vulnerabilities such as SQL injection, cross-site scripting (XSS), and misconfigurations in public-facing web applications can be exploited by attackers.

-Conduct rigorous security assessments: Regularly conduct penetration tests and vulnerability assessments using tools like Burp Suite, OWASP ZAP, or Qualys.

-Implement robust web application firewalls (WAF): Deploy WAFs, such as AWS WAF or Cloudflare, to protect against common threats like injection attacks.

-Adhere to secure coding practices: Enforce secure coding practices, including input validation, output encoding, and the principle of least privilege.

-Implement real-time monitoring: Perform real-time application monitoring to detect and respond to suspicious behavior.

5. Public Repository Security

Sensitive information, such as API keys and credentials, may be inadvertently exposed in public repositories like GitHub.

-Proactively scan for exposed secrets: Utilize tools like GitGuardian, TruffleHog, or Gitleaks to scan repositories for exposed secrets.

-Enforce strict code review processes: Implement a rigorous code review process to prevent accidental or malicious data leakage.

-Promote secure credential management: Train developers to avoid hardcoding credentials and utilize secure vaults like HashiCorp Vault or AWS Secrets Manager.

-Regularly audit and clean up repositories: Regularly audit and remove unnecessary public repositories.

6. Third-Party Integration Security

Vulnerabilities within third-party tools or services can create significant security risks, including data breaches and unauthorized access.

-Conduct thorough vendor security assessments: Regularly conduct security audits of third-party vendors and services to ensure compliance with Nexus Dynamics's security policies.

-Implement the principle of least privilege: Limit third-party access to sensitive data by adhering to the principle of least privilege.

-Maintain up-to-date integrations: Ensure all third-party integrations are patched and updated promptly to address known vulnerabilities.

-Embrace a zero-trust approach: Implement a zero-trust architecture to validate and secure all third-party access.

7. Continuous Monitoring and Threat Intelligence

The evolving threat landscape necessitates continuous monitoring and adaptation to emerging vulnerabilities and threats.

-Implement robust security information and event management (SIEM) solutions: Utilize SIEM solutions such as Splunk, IBM QRadar, or ELK Stack for real-time monitoring and threat detection.

-Leverage threat intelligence feeds: Subscribe to threat intelligence feeds to stay informed about emerging risks targeting the technology and consulting sectors. **-Conduct regular security exercises:** Conduct red team/blue team exercises to test and improve the organization's response to security incidents.

8. Employee Awareness and Training (Human Behaviour)

Human error remains a significant factor in security breaches.

-Conduct regular cybersecurity awareness training: Implement comprehensive cybersecurity awareness training programs for all employees, focusing on phishing, social engineering, and secure online behavior.

-Establish a clear incident reporting process: Establish a clear and accessible incident reporting process for employees to report suspicious activities without fear of reprisal.

-Foster a culture of security: Promote a culture of cybersecurity by recognizing and rewarding employees for identifying and reporting potential threats.

9. Disaster Recovery and Incident Response

Delayed or ineffective response to a security incident can significantly exacerbate its impact.

-Develop and maintain an incident response plan (IRP): Develop and regularly update an incident response plan (IRP) to ensure timely detection, containment, and remediation of security incidents.

-Conduct regular disaster recovery drills: Perform disaster recovery drills to test and refine the organization's ability to recover from major incidents.

-Invest in robust backup and recovery solutions: Invest in and maintain robust backup and recovery solutions to ensure critical data can be restored in case of a ransomware attack or data loss.

These are to:

-Improve clarity and conciseness: The language is more direct and avoids unnecessary jargon.

Enhance impact: The language is more impactful and emphasizes the importance of each recommendation. **Improve flow and readability:** The language is more consistent and easier to read.

REFERENCES

Agarwal, S., Sprick, B. and Wortmann, S., 2004, March. Credential based access control for semantic web services. In AAAI Spring Symposium-Semantic Web Services (Vol. 1, No. 1).

Cybereason Nocturnus (2018). Operation Soft Cell: A Worldwide Campaign Against Telecommunications Providers. [online] Cybereason.com. Available at: https://www.cybereason.com/blog/research/operation-soft-cell-a-worldwide-campaign-against-telecommunications-providers? [Accessed 24 Jan. 2025].

Cybersecurity and Infrastructure Security Agency CISA. (2025). Cybersecurity Alerts & Advisories | CISA. [online] Available at: https://www.cisa.gov/news-events/cybersecurity-advisories [Accessed 27 Jan. 2025].

Fortinet. (2023). Indicators of Compromise (IOCs) | Fortinet. [online] Available at: https://www.fortinet.com/resources/cyberglossary/indicators-of-compromise [Accessed 24 Jan. 2025].

Georgiadou, A., Spiros Mouzakitis and Dimitris Askounis (2021). Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework. Sensors, [online] 21(9), pp.3267–3267. doi:https://doi.org/10.3390/s21093267.

Ibm.com. (2025). Enterprise Security Solutions | IBM. [online] Available at: https://www.ibm.com/security [Accessed 27 Jan. 2025].

Ibm.com. (2025). IBM - United States. [online] Available at: https://www.ibm.com/us-en [Accessed 27 Jan. 2025].

Macrotrends.net. (2024). IBM: Number of Employees 2010-2024 | IBM. [online] Available at: https://www.macrotrends.net/stocks/charts/IBM/ibm/number-of-employees [Accessed 27 Jan. 2025].

Mandiant (2017). APT10 (MenuPass Group): New Tools, Global Campaign Latest Manifestation of Longstanding Threat. [online] Google Cloud Blog. Available at: https://cloud.google.com/blog/topics/threat-intelligence/apt10-menupass-group [Accessed 24 Jan. 2025].

Mitre.org. (2016). menuPass, Cicada, POTASSIUM, Stone Panda, APT10, Red Apollo, CVNX, HOGFISH, BRONZE RIVERSIDE, Group G0045 | MITRE ATT&CK®. [online] Available at: https://attack.mitre.org/groups/G0045/ [Accessed 24 Jan. 2025].

Mitre.org. (2024). CVE - CVE. [online] Available at: https://cve.mitre.org/ [Accessed 27 Jan. 2025].

Naik, N., Jenkins, P., Grace, P. and Song, J. (2022). Comparing Attack Models for IT Systems: Lockheed Martin's Cyber Kill Chain, MITRE ATT&CK Framework and Diamond Model. [online] doi:https://doi.org/10.1109/isse54508.2022.10005490.

NIST. (2013). Cybersecurity Framework | NIST. [online] Available at: https://www.nist.gov/cyberframework [Accessed 27 Jan. 2025].

Sayegh, E. (2023). Spotlight On APT10. [online] Forbes. Available at: https://www.forbes.com/sites/emilsayegh/2023/02/21/spotlight-on-apt10/ [Accessed 27 Jan. 2025].

SecurityScorecard. (2024). A Deep Dive Into ALPHV/BlackCat Ransomware. [online] Available at: https://securityscorecard.com/research/deep-dive-into-alphv-blackcat-ransomware/ [Accessed 27 Jan. 2025].

Special Reports (2019). Stealing Clouds. [online] Reuters. Available at: https://www.reuters.com/investigates/special-report/china-cyber-cloudhopper/ [Accessed 27 Jan. 2025].

Statista. (2024). DXC Technology employees 2024 | Statista. [online] Available at: https://www.statista.com/statistics/726694/worldwide-dxc-technology-number-of-employees-by-year/ [Accessed 27 Jan. 2025].

Threat Report: APT10. (2019). Available at: https://www.forescout.com/resources/apt10/?utm_source=chatgpt.com [Accessed 24 Jan. 2025].

to, C. (2019). Chinese cyberespionage group. [online] Wikipedia.org. Available at: https://en.wikipedia.org/wiki/Red_Apollo [Accessed 24 Jan. 2025].

to, C. (2023). criminal hacking organization. [online] Wikipedia.org. Available at: https://en.wikipedia.org/wiki/LockBit [Accessed 27 Jan. 2025].

Tidy, J. (2023). Hacker gang Clop publishes victim names on dark web. [online] Bbc.com. Available at: https://www.bbc.com/news/business-65924327 [Accessed 27 Jan. 2025].

Trend Micro. (2024). Spot the Difference: Earth Kasha's New LODEINFO Campaign And The Correlation Analysis With The APT10 Umbrella. [online] Available at: https://www.trendmicro.com/en_us/research/24/k/lodeinfo-campaign-of-earth-kasha.html [Accessed 24 Jan. 2025].

Virustotal.com. (2025). *VirusTotal*. [online] Available at: https://www.virustotal.com/gui/search/chessmaster/comments [Accessed 24 Jan. 2025].

Wang, X., Zheng, K., Niu, X., Wu, B. and Wu, C. (2016). Detection of command and control in advanced persistent threat based on independent access. [online] doi:https://doi.org/10.1109/icc.2016.7511197

Web Editor (2024). APT10 Uses NOOPDOOR and LODEINFO Malware to Attack Japanese Companies – Active IOCs - Rewterz. [online] Rewterz - Revolutionizing Cybersecurity. Available at: https://www.rewterz.com/threat-advisory/apt10-uses-noopdoor-and-lodeinfo-malware-toattack-japanese-companies-active-iocs [Accessed 24 Jan. 2025].